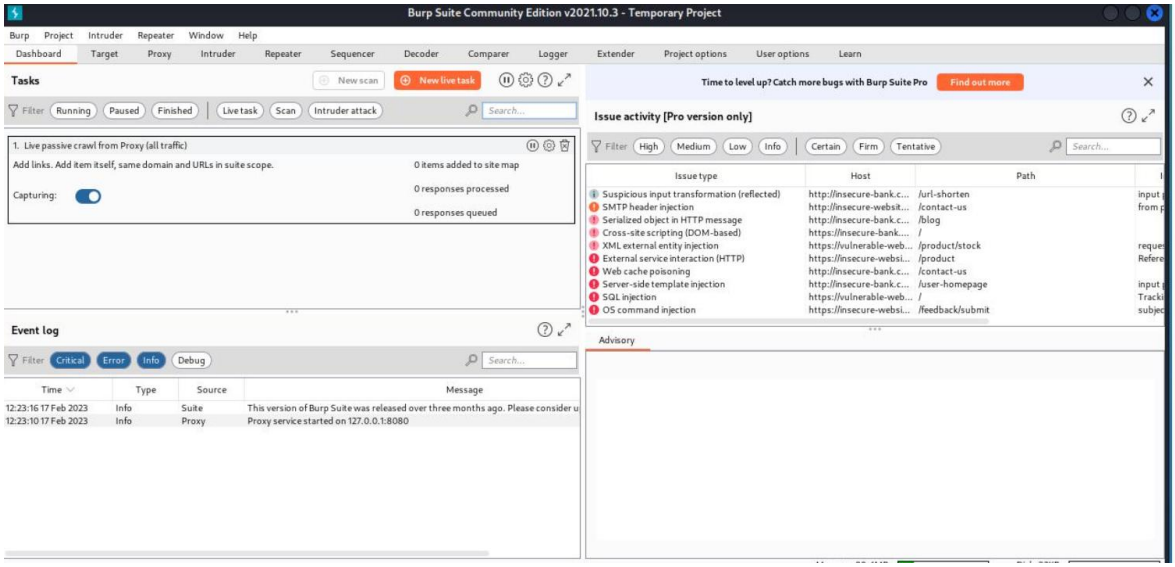
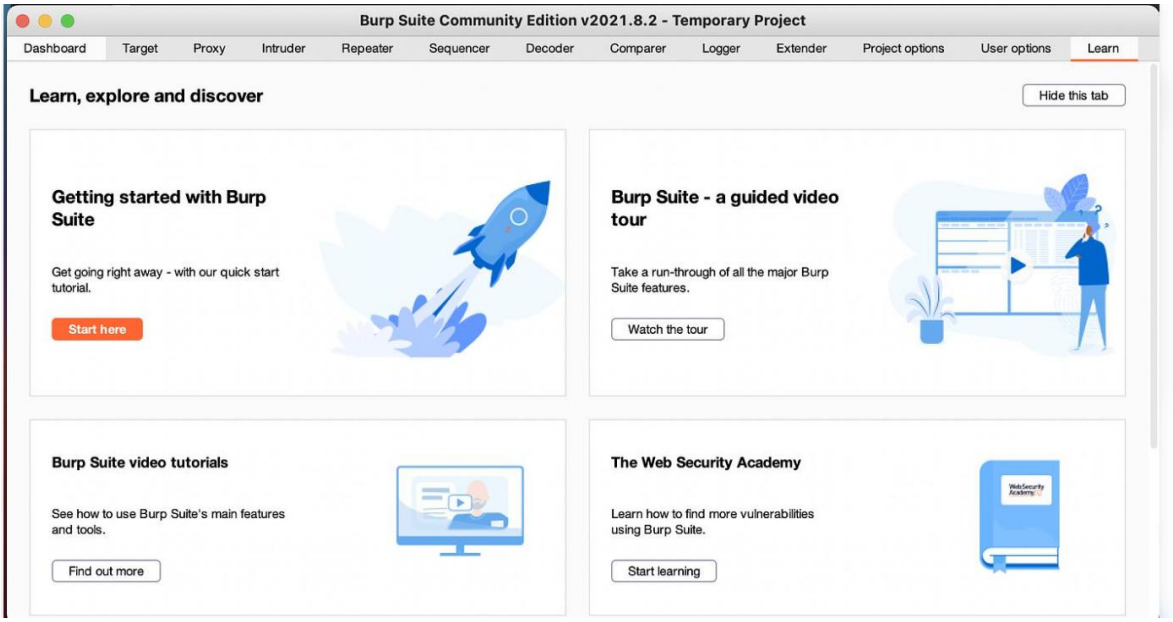
1.Download and install Burp Suite Community Edition on your system, then launch it and take a screenshot of the main dashboard.

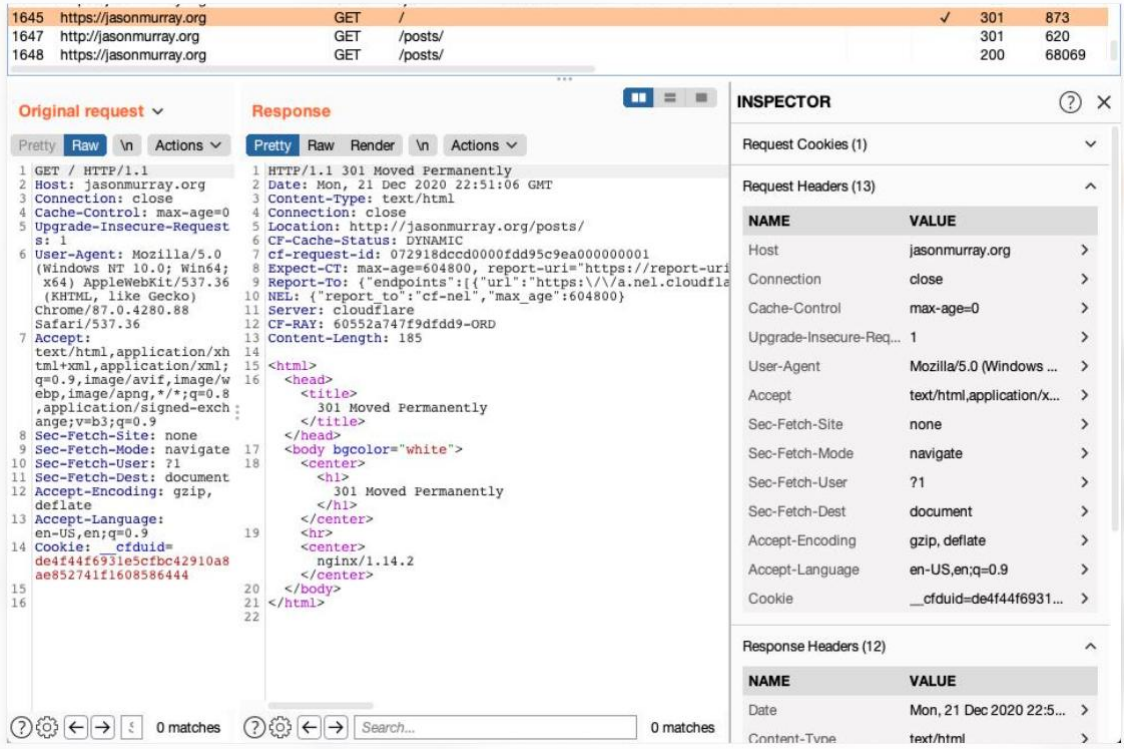
Ans-





2.Use Burp Suite's Proxy feature to intercept HTTP requests while browsing the login page of any demo web app (such as http://testphp.vulnweb.com/) and list the intercepted request headers.

Ans-



3.Visit the OWASP official website and identify three open-source VAPT tools listed there (other than Burp Suite). For each, write a one-line description of its main purpose.

Ans-

Step 1: Visit the OWASP website

Open:

OWASP Official Website

OWASP stands for Open Worldwide Application Security Project. It provides resources and tools to improve application security.

Step 2: Identify three OWASP tools

You can use these three open-source security tools:

File:OWASP ZAP logo.svg - Wikimedia Commons

1. OWASP ZAP

Zed Attack Proxy is used to find security vulnerabilities in web applications through automated and manual testing.

Website: OWASP ZAP

2. OWASP Amass

Used for network mapping and external asset discovery to identify an organization's internet-facing infrastructure.

Website: OWASP Amass

Detecting dependencies with known vulnerabilities | Vojtech Ruzicka's Programming Blog

3. OWASP Dependency-Check

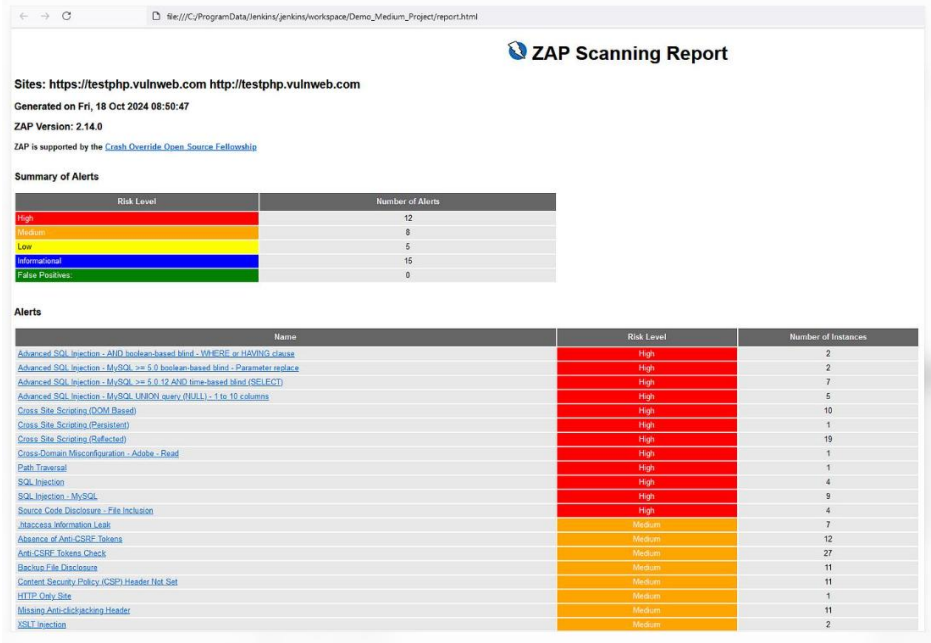
Scans project dependencies and identifies known vulnerabilities in third-party libraries.

Website: Dependency-Check

**4.Perform a basic vulnerability scan on http://testphp.vulnweb.com/ using OWASP ZAP (or any OWASP-listed tool), and list two vulnerabilities or alerts detected by the tool.

Hint: Use the 'Quick Start' or 'Automated Scan' option for faster results.**

Ans-



file:///C:/ProgramData/Jenkins/.jenkins/workspace/Demo_Medium_Project/report.html

ZAP Scanning Report

Sites: https://testphp.vulnweb.com http://testphp.vulnweb.com

Generated on Fri, 18 Oct 2024 08:50:47

ZAP Version: 2.14.0

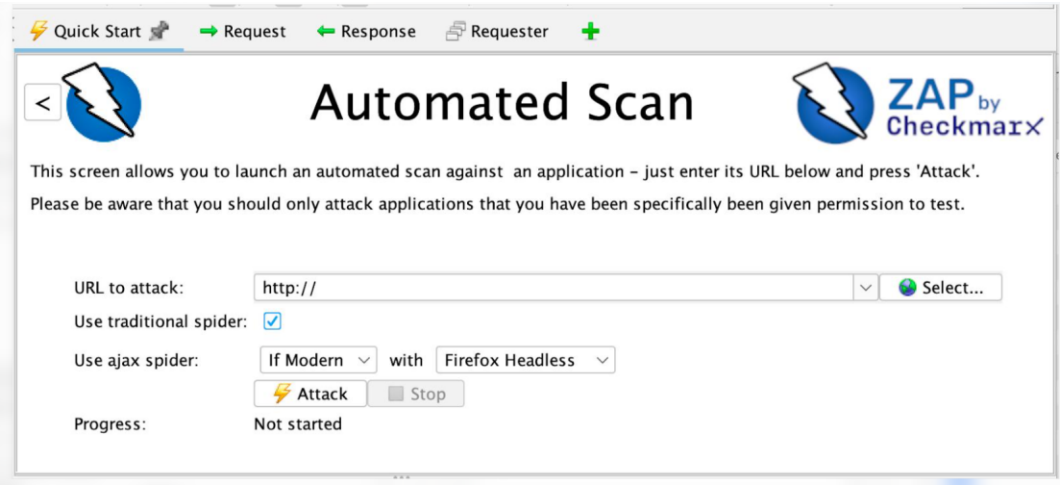
ZAP is supported by the Crash Override Open Source Fellowship

Summary of Alerts

Risk Level	Number of Alerts
High	12
Medium	8
Low	5
Informational	15
False Positives:	0

Alerts

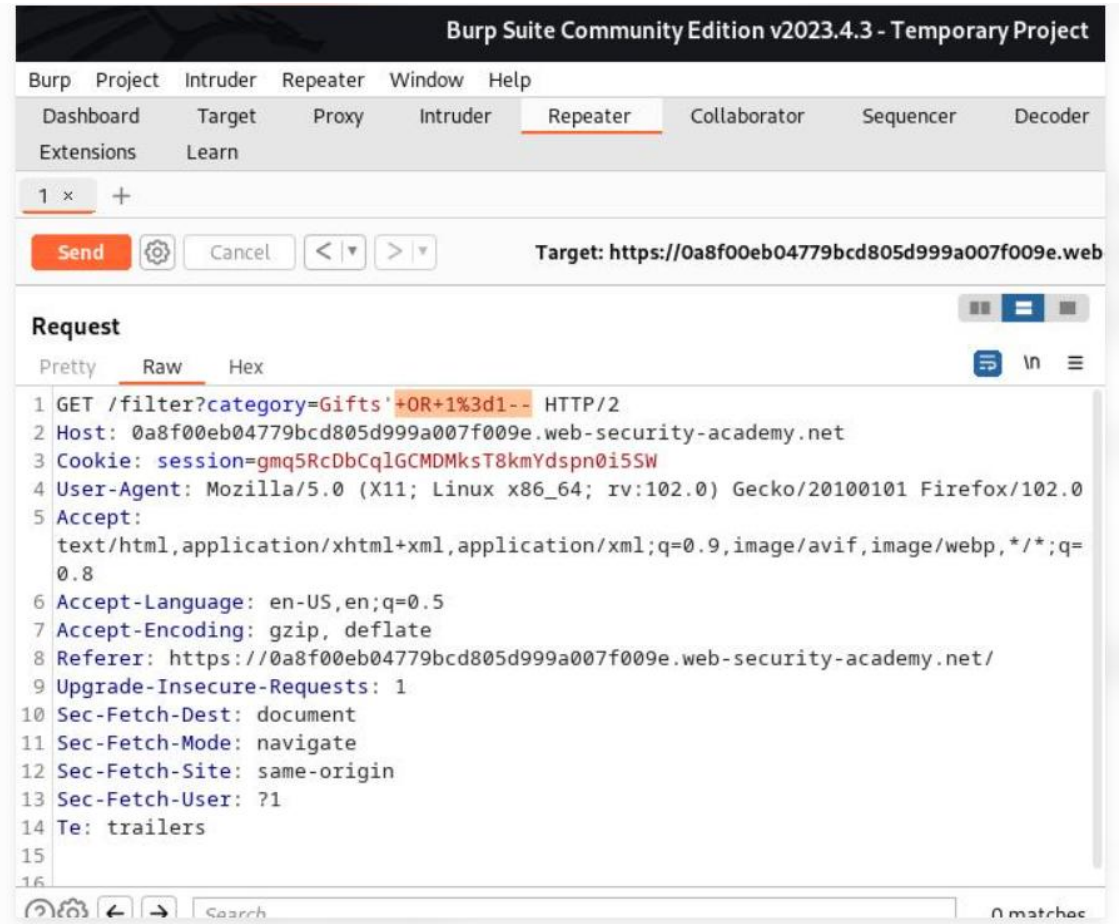
Name	Risk Level	Number of Instances
Advanced SQL Injection - AND boolean-based blind - WHERE or HAVING clause	High	2
Advanced SQL Injection - MySQL >= 5.0 boolean-based blind - Parameter replace	High	2
Advanced SQL Injection - MySQL >= 5.0.12 AND time-based blind (SELECT)	High	7
Advanced SQL Injection - MySQL UNION query (NULL) - 1 to 10 columns	High	5
Cross Site Scripting (DOM Based)	High	10
Cross Site Scripting (Persistent)	High	1
Cross Site Scripting (Reflected)	High	19
Cross-Domain Misconfiguration - Adobe - Read	High	1
Path Traversal	High	1
SQL Injection	High	4
SQL Injection - MySQL	High	9
Source Code Disclosure - File Inclusion	High	4
.htaccess Information Leak	Medium	7
Absence of Anti-CSRF Tokens	Medium	12
Anti-CSRF Tokens Check	Medium	27
Backup File Disclosure	Medium	11
Content Security Policy (CSP) Header Not Set	Medium	11
HTTP Only Site	Medium	1
Missing Anti-clickjacking Header	Medium	11
XSLT Injection	Medium	2

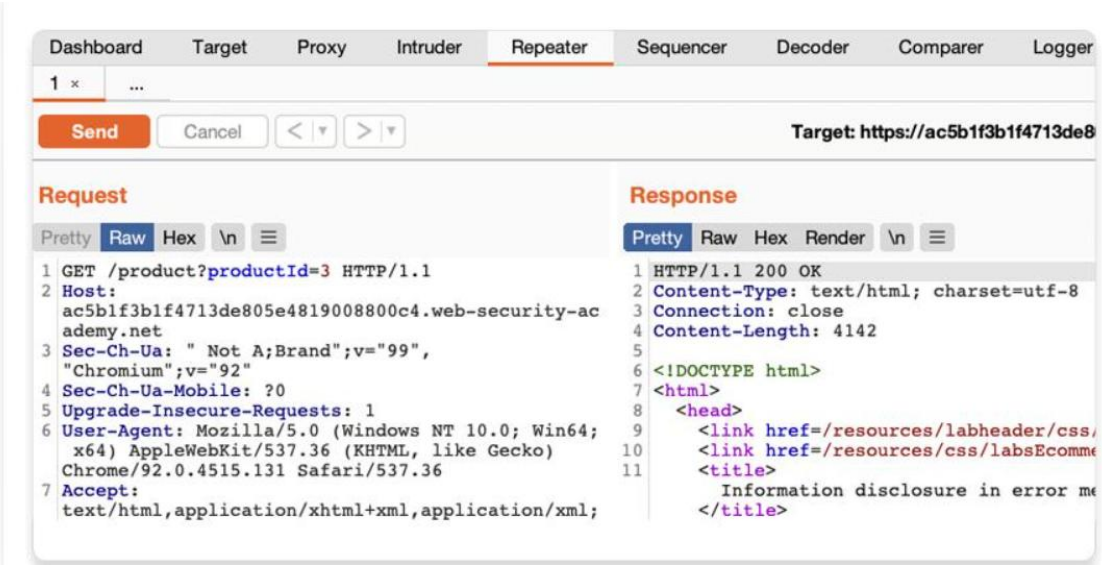


**5.Use ChatGPT or Copilot to generate a step-by-step guide for running a simple SQL Injection test using Burp Suite on a demo site, then follow the steps and note any differences or issues you faced.

Hint: Paste the AI-generated steps and your observations in your submission.**

Ans-




Dashboard
Target
Proxy
Intruder
Repeater
Sequencer
Decoder
Comparer
Logger
1 ×
...
Send
Cancel
Target: https://ac5b1f3b1f4713de8
Request
Pretty Raw Hex \n
1 GET /product?productId=3 HTTP/1.1
2 Host: ac5b1f3b1f4713de805e4819008800c4.web-security-academy.net
3 Sec-Ch-Ua: " Not A;Brand";v="99", "Chromium";v="92"
4 Sec-Ch-Ua-Mobile: ?0
5 Upgrade-Insecure-Requests: 1
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/92.0.4515.131 Safari/537.36
7 Accept: text/html,application/xhtml+xml,application/xml;
Response
Pretty Raw Hex Render \n
1 HTTP/1.1 200 OK
2 Content-Type: text/html; charset=utf-8
3 Connection: close
4 Content-Length: 4142
5
6 <!DOCTYPE html>
7 <html>
8 <head>
9 <link href=/resources/labheader/css/
10 <link href=/resources/css/labsEcomme
11 <title>
Information disclosure in error me
</title>